License Manager

Localhost Audit and Implementation Scope

Target: http://localhost:8000/ | Evidence captured: 31 October 2026

Executive conclusion

The local instance is available and serves the React application shell successfully. Public health and OpenAPI endpoints respond; unauthenticated business endpoints correctly reject access. The audit does not establish authenticated workflow correctness, data integrity or production readiness because browser automation was unavailable and no credentials/test data were supplied.

Live check	Observed result	Assessment
GET /	HTTP 200; 1,036-byte SPA HTML; JS/CSS asset references	PASS - shell reachable
GET /api/health/	HTTP 200 {status: ok}	PASS - process health only
GET /api/schema/	HTTP 200; OpenAPI 3.0.3; 481,089 bytes	PASS - API schema exposed
GET /api/auth/me/, dashboard, reconciliation, companies	HTTP 401; Bearer challenge	PASS - unauthenticated access rejected
Browser interaction	Browser provider unavailable	BLOCKED - no UI claim

Observed errors and audit limitations

ID	Severity	Finding / evidence	Implementation needed
LIVE-01	P2	Local response identifies WSGIServer/CPython. This is acceptable for local development but not production evidence.	Verify production ASGI/WSGI server, TLS, proxy headers, logging and rate limiting in staging.
LIVE-02	P2	No authenticated browser or API workflow was executed; local HTTP checks cannot validate pages, forms or permissions by role.	Provide isolated test account/data or staging environment; run role-based workflow and accessibility suite.
QA-01	P2	Frontend suite previously executed: 543/544 tests passed; stale planning payload expectation fails.	Agree API request contract then update/add regression test.
QA-02	P2	Frontend lint previously executed: 3 ESM require errors and 9 warnings.	Make lint clean before release; migrate script or configure lint scope.
SEC-01	P0 SaaS	Repository review shows global role model and unscoped company/domain reads in material paths.	Tenant/membership context, scoped repositories, object checks, isolation tests and backfill.
DFR-01	P1	Restriction pool groups by free-text percentage, not explicit group membership.	Versioned restriction rule/group/member and immutable usage/reservation ledger.

What is currently evidenced

The repository contains Django/DRF APIs and React SPA routes for licences, SION planning, allotments, BOEs, trades, reports, ledger packages, masters and BOE-to-invoice reconciliation. Atomic transactions and row locks exist in critical planning/allotment paths. The reconciliation module is not bank reconciliation; it performs explicit BOE/invoice triage. Commercial invoice and trade payment models exist, but no general-ledger, journal-entry, chart-of-accounts, bank-statement or bank-transaction domain was found.

Required implementation scope

Phase	Scope	Definition of done
0. Baseline	Confirm deployed commit, create isolated test harness, characterise current balances/restrictions and inventory permissions.	Repeatable test environment; baseline examples and known gaps signed off.
1. Protection	Choose internal vs external SaaS; tenant isolation, idempotency and role/object tests.	Cross-tenant negative tests pass; unscoped access is blocked.
2. Single source of truth	Canonical backend balance/restriction service; migrate reports/APIs/UI incrementally.	Preview, commit and reports agree on golden data and concurrency cases.
3. UX foundation	Route manifest, shared forms/tables/states, high-risk workflow redesign and accessibility gate.	Keyboard/responsive/error/empty/loading behaviour verified in E2E.
4. DFIA/SION restrictions	Explicit 2/3/5/10% individual/shared pools; AU policy; audit explanation and locking.	No overspend under concurrent allocations; every result explains rule/base/usage.
5. Accounting	Tenant/legal entity, chart, immutable balanced journals, subledgers, posting/reversal/period controls.	Every posted entry balances; AR/AP and trial balance reconcile.
6. Bank reconciliation	Statement import, normalisation, duplicate controls, matching/manual review, totals and audit history.	End-to-end statement-to-ledger reconciliation tested including split/combined/override.

Restriction, accounting and bank design requirements

Restriction planning

Do not equate existing CIF condition pools and SION quantity percentage capacity until the business meaning is formally agreed. The new resolver should select an effective versioned rule, determine scope and group, calculate historical and planned use, lock a shared pool at commit, create an immutable consumption/reservation event and return a human-readable explanation. Invalid or conflicting configuration must warn/block rather than quietly permit allocation.

Accounting

Build the double-entry core before P&L;, balance sheet, advanced tax or Tally replacement. Required controls are: company/tenant-scoped chart, voucher numbering and states, Decimal/currency precision, idempotent source references, immutable posted lines, debit-credit equality, reversals, period locks, audit trail and subledger reconciliation. Indian GST/TDS/export treatment requires qualified tax review.

Bank reconciliation

Implement it as a separate bounded context: statement batch/import preview, source-row retention and fingerprinting, canonical bank transactions, deterministic explainable matching, manual split/combined review, appropriate accounting postings and completion/reopen history. Start with validated CSV/XLSX; do not promise reliable PDF/bank-specific parsing without representative samples.

Management decisions that unblock delivery

Decision	Why it is required
Deployment target and release authority	Local HTTP success does not establish the deployed revision, configuration or operational controls.
Internal multi-company vs external SaaS	Determines tenant model, migration strategy, security and commercial scope.
2/3/5/10% and AU definitions	Determines rule base, shared-pool membership, priority, historical use and overrides.
Accounting first-release and tax policy	Prevents building reports on unreliable financial foundations.
Bank formats and Tally migration	Bounds adapters, import/mapping work and data-reconciliation effort.

Verification plan before production

Use a seeded, isolated database/Redis namespace and role-specific accounts. Gate release on clean lint/typecheck/tests; backend unit/integration tests for Decimal, balances, restrictions and accounting invariants; API permission/tenant negatives; browser E2E for licence-to-allotment-to-BOE/trade flows; accessibility/mobile checks; migration/backfill reconciliation; load benchmarks; task retry/idempotency checks; and backup/restore rehearsal. Never treat static source review or an HTTP 200 as a completed financial workflow.

Evidence notes

Live evidence was captured via safe GET requests to localhost only. No credentials, mutations, data changes or destructive operations were used. The initial full repository assessment reports are located under docs/assessment/. The mandated repository code index was absent, which limits dependency-graph evidence. This document is a management scope report, not an implementation or production-readiness certification.